Security Self Assessment

cubic.ai Insurance extension

Project: cubic.ai Insurance

Assessment purpose: Self-attestation of implemented security and privacy controls for the competition submission.

Scope: The insurance extension integrated into the local cubic.ai interface, including policy upload, policy Q&A;, coverage-gap analysis, claims guidance, sandbox submission and the policy-to-chat handoff.

Attestation

We attest that this assessment accurately describes the controls implemented in the submitted cubic.ai Insurance source code at the time of submission. The system is a local demonstration application. It does not connect to a production insurer and it must not be used as legal, financial or insurance advice.

Implemented controls

Area	Implemented control	Evidence
Authentication	Signed local session cookies, PBKDF2 password hashing and login throttling.	auth.py and the base project security tests.
Policy access	Uploaded policies are stored per signed-in user. Insurance routes resolve only the current user's policy store.	insurance_api.py user-keyed policy folders and access checks.
Input validation	Strict request models validate identifiers, dates, claim amounts and document lists.	FastAPI/Pydantic models in insurance_api.py.
Tool permissions	Read, Draft and Submit tiers gate insurance tools.	insure/agent.py and insure/permissions.py.
Submission safeguard	Sandbox submission needs a temporary submit permission and an explicit confirmation.	insurance_api.py submit-permission and submit routes.
Audit integrity	Allowed and denied tool calls create hash-chained audit entries that can be verified.	insure/permissions.py and audit verification route.
Repository privacy	Git ignores local accounts, policies, audit data, claim drafts, models and environments.	Repository .gitignore.

Data handling

The intended deployment runs the application locally. The model service is Ollama on localhost when model assistance is enabled. Policy PDFs, user accounts, chat state, audit logs and sandbox claim state remain local to the machine and are excluded from the published source repository.

Known limitations and residual risks

Risk or limitation	Treatment in this submission
Policy interpretation	Answers are decision support only. The interface shows citations and instructs users to check the cited clause and insurer.
Clause extraction quality	Users review extracted clause categories before relying on an uploaded policy. Scanned or unusual PDFs may need manual review.
Retrieval gaps	The default insurance retrieval is keyword based. A paraphrase with little shared wording may be missed and should result in clarification or insurer follow-up.
Coverage determination	Covered, excluded and unclear results are policy-text assessments, not claim approval decisions. Possible exclusions remain visible.
Sandbox claims	The insurer integration is a mock sandbox with simple rules. It does not transmit claims to a real insurer.
Local endpoint exposure	The normal local deployment uses localhost. LAN exposure should be enabled only when the operator understands the network and certificate settings.
Model availability	A local model may be unavailable or return no usable answer. Citation-grounded extraction and abstention remain available.

Supporting evidence

The final project report, *Offline Agentic RAG: A Multimodal Framework for Localized Intelligence using VLMs and QLoRA-Adapted Retrieval*, provides supporting evidence for the base cubic.ai system. It documents local operation, authentication, user isolation, security tests, privacy monitoring and known limitations. This self-assessment adds the insurance-specific controls implemented after that report.

Declaration and signatures

By signing below, the team confirms that the statements above describe the submitted system and that the known limitations have not been hidden.

Team member	USN	Signature	Date
Tanisha Kiran	1AH23CD056	_____	_____
Kurrath ul Ain	1AH23CD021	_____	_____
Madhushree	1AH23CD043	_____	_____

Prepared for competition submission. Complete the signature fields before submitting.